Lab 08 — Identity, MFA, and account abuse

Course: Maxim Nyansa Cybersecurity Bootcamp, Ghana
Trainee: James Ackah Blay · Aiyinasi, Ghana
Week: 8 — Identity and access management
Estimated time: 6 hours
Difficulty: Advanced. You will separate who someone is, how they prove it, and what they may do, then detect a privileged change.

> **Tutor note.** Create lab accounts only on machines you own. Remove them at the end. Do not reuse a personal password. The detection half can be done from the synthetic CSV if the Windows VM is not ready. Say which source you used.

1. Learning objectives

Objective	Job skill
Write password and MFA rules you can test	Identity policy, not a slogan
Map a sign-in and a delegated-access story	The questions behind SSO, OAuth 2.0, and OpenID Connect
Build a role matrix with separation of duties	RBAC, and when an attribute such as on-call changes the answer
Detect failed logons and a new administrator	Daily SOC work: 4625, 4720, 4732

2. Prerequisites and setup

Week 2 Windows VM at `192.168.56.20` if you will generate live events. Python 3 for `account_events.py`. The policy checker:

```
python3 -m pytest week-08-identity-access-management/password-mfa-policy
```

Optional: Keycloak in Docker, localhost only, for a real sign-in screen.

```
docker run --rm -d --name keycloak -p 127.0.0.1:8080:8080 \
  -e KC_BOOTSTRAP_ADMIN_USERNAME=labadmin \
  -e KC_BOOTSTRAP_ADMIN_PASSWORD='replace-this-local-password' \
  quay.io/keycloak/keycloak start-dev
```

If the container exits, read `docker logs keycloak` and the current Keycloak container guide. Older images used `KEYCLOAK_ADMIN` and `KEYCLOAK_ADMIN_PASSWORD`. Do not publish port 8080 on the house LAN. Stop it when you finish: `docker stop keycloak`.

3. Scenario

A lab “company” has an analyst, a senior analyst, and a platform admin. Someone will add a local administrator because it is faster. Your job is to make that change visible, and to decide whether the password and the second factor would have mattered.

4. Tasks

Task 1 — Policy you can fail on purpose

Fill `../password-mfa-policy/policy.md`. Then:

```
        python3 ../password-mfa-policy/password_policy.py --password 'Harbour-Lab-2026!' --
username analyst
        python3 ../password-mfa-policy/password_policy.py --password 'changeme'
```

Use a throwaway string. Do not test your real email password on a command line.

> **You should now see** one JSON object with `"accepted": true` and one with reasons. MFA in the policy may still say “not available on the VM”. That is honest. Two passwords are still one factor type.

Task 2 — Journeys

Fill `../iam-user-journey/user-journey.md`. Journey A is the Wazuh dashboard. Journey B stays a paper exercise. Do not create an OAuth client against a production identity provider.

If Keycloak is running, create one lab user in the UI and sign in once. Record the URL (`127.0.0.1`) and that you stopped the container. Do not record the password.

Task 3 — Matrix

Read `../access-control-matrix/access-matrix.csv`. Change a cell only with a sentence. The platform admin prepares an account. The team lead approves it. Those are not the same person in this matrix.

Task 4 — Detect the abuse pattern

On the synthetic file:

```
        python3 account_events.py samples/security-events.csv
```

The file includes failed logons (4625), a created account (4720), and a member added to Administrators (4732). A Backup Operators change is present so you can see that not every group is this alert.

> **You should now see** a brute-force note for `203.0.113.10` and one new-admin line for `newadmin`. `203.0.113.10` is documentation space. Do not contact it.

Task 5 — Optional live event on your Windows VM

In an elevated prompt, create a lab user and add it to Administrators, then remove it before you finish:

```
        net user labuser Replace-This-Local-1 /add
        net localgroup Administrators labuser /add
        wevtutil qe Security /q:"*[System[(EventID=4732)]]" /c:3 /f:text
        net localgroup Administrators labuser /delete
        net user labuser /delete
```

If `wevtutil` shows no 4732 yet, write that. Do not invent the event. Export nothing that contains a real person's password.

5. Troubleshooting

What you see	What it means
Keycloak exits immediately	The image wanted different environment variables. Read the log before you try a second product
`net` is denied	The prompt is not elevated
4732 query is empty	The security log has not flushed, or you are not looking at the right VM
Detector flags Backup Operators	The group filter is wrong. The test expects only Administrators

6. Stretch task

Propose the least-privilege change in `../least-privilege-proposal/proposal.md` and tie it to event 4732: what you will log, who approves, and how you will know the lab user is gone.

7. Evidence

- Policy checker JSON for a pass and a fail, using throwaway strings.
- Journey notes.
- Detector output labelled synthetic, plus live 4732 text only if you generated it.
- Proof the lab user was deleted, if you created one.

8. Reflection

1. Which factor types does your policy actually have today?
2. Why is approval separated from account creation?
3. What would a 4732 at 02:00 mean if nobody was supposed to be building the VM?

9. Interview questions

1. Identification, authentication, authorisation: define each.
2. Why are two passwords not MFA?
3. What is separation of duties?
4. Which Windows events tell you a local admin appeared?
5. What is OAuth 2.0 for, in one sentence, and what does OpenID Connect add?

10. Grading rubric

Criterion	Exceeds	Meets	Not yet
Policy	MFA gaps are named, not pretended away	Checker output for pass and fail	A real password on the command line
Matrix	You defend one cell you changed, or why you changed none	The approval split is understood	One shared admin for every task
Detection	Live 4732 quoted, or a clear “not generated”	Synthetic output interpreted	Sample file called a real incident
Cleanup	Lab user removed	You still have a note to remove it	A new admin left behind with no ticket